IKB21403: VULNERABILITY ANALYSIS

# CHAPTER 2: SYSTEM HACKING

Prepared by: Dr. Shafiza Mohd Shariff
Edited by: Ts. Herny Ramadhani

# SYSTEM HACKING CONCEPTS

The act of attempting to manipulate the normal behavior of a system, usually a computer system, to gain unauthorized access or perform unauthorized actions.

System hacking is about exploiting weaknesses:

- system's design
- implementation
- in the behaviors of its users.

GOAL

To gain control over the system, allowing attackers to:

- execute commands
- access confidential information
- disrupt services
- perform other malicious activities

# STAGES OF SYSTEM HACKING

- Reconnaissance
- Scanning
- Gaining Access
- Escalate Privileges
- Maintaining Access
- Clearing Tracks

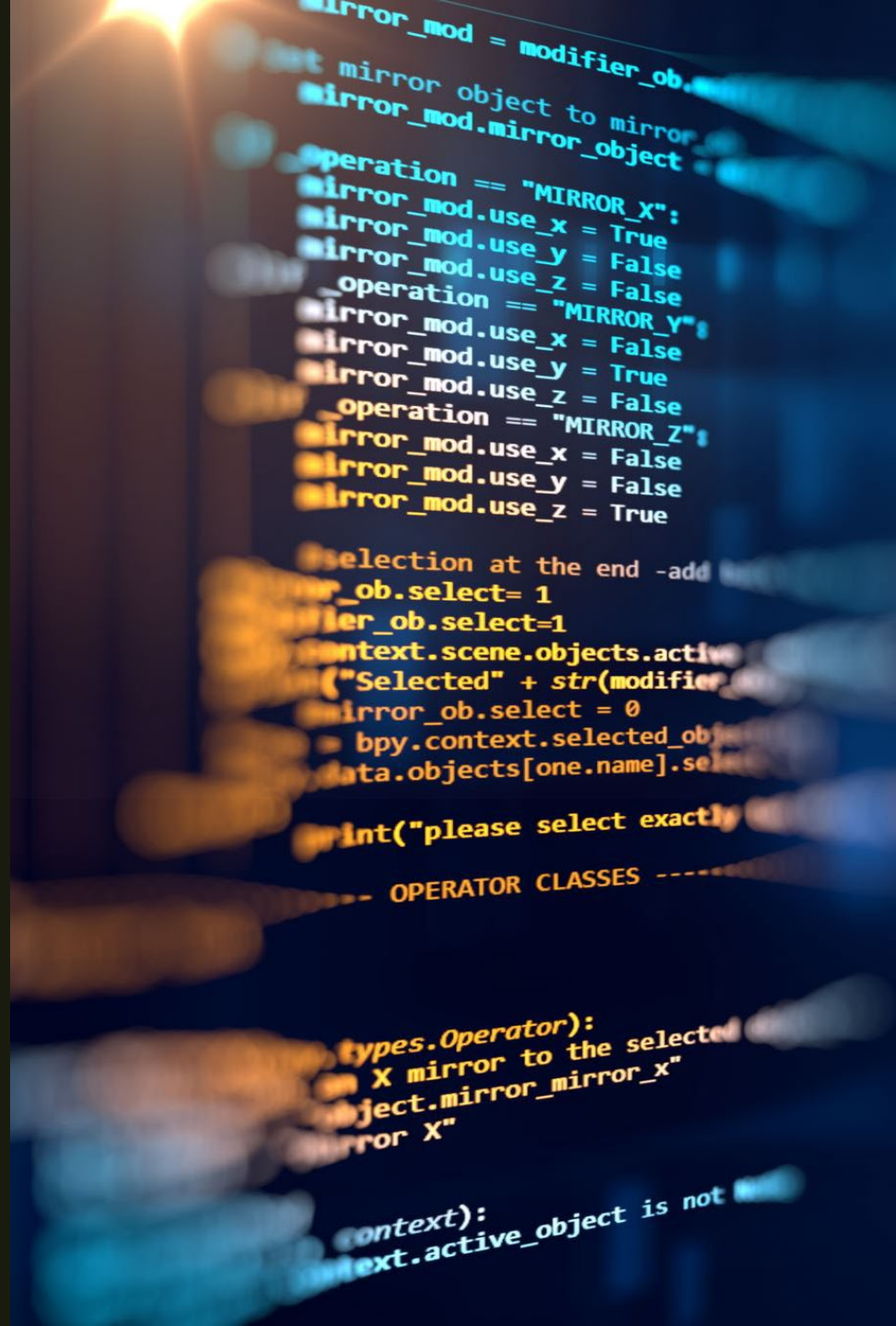
# COMMON SYSTEM HACKING TECHNIQUES

## Password Cracking

- **Brute force attacks:** combination of characters
- **Dictionary attacks:** words in dictionary / common passwords
- **Rainbow tables:** storing password hashes

## Phishing

- **Spear phishing:** specific target
- **Whaling:** executives or decision makers
- **Clone phishing:** duplicate previous email



# COMMON SYSTEM HACKING TECHNIQUES

## Rootkits and Trojans

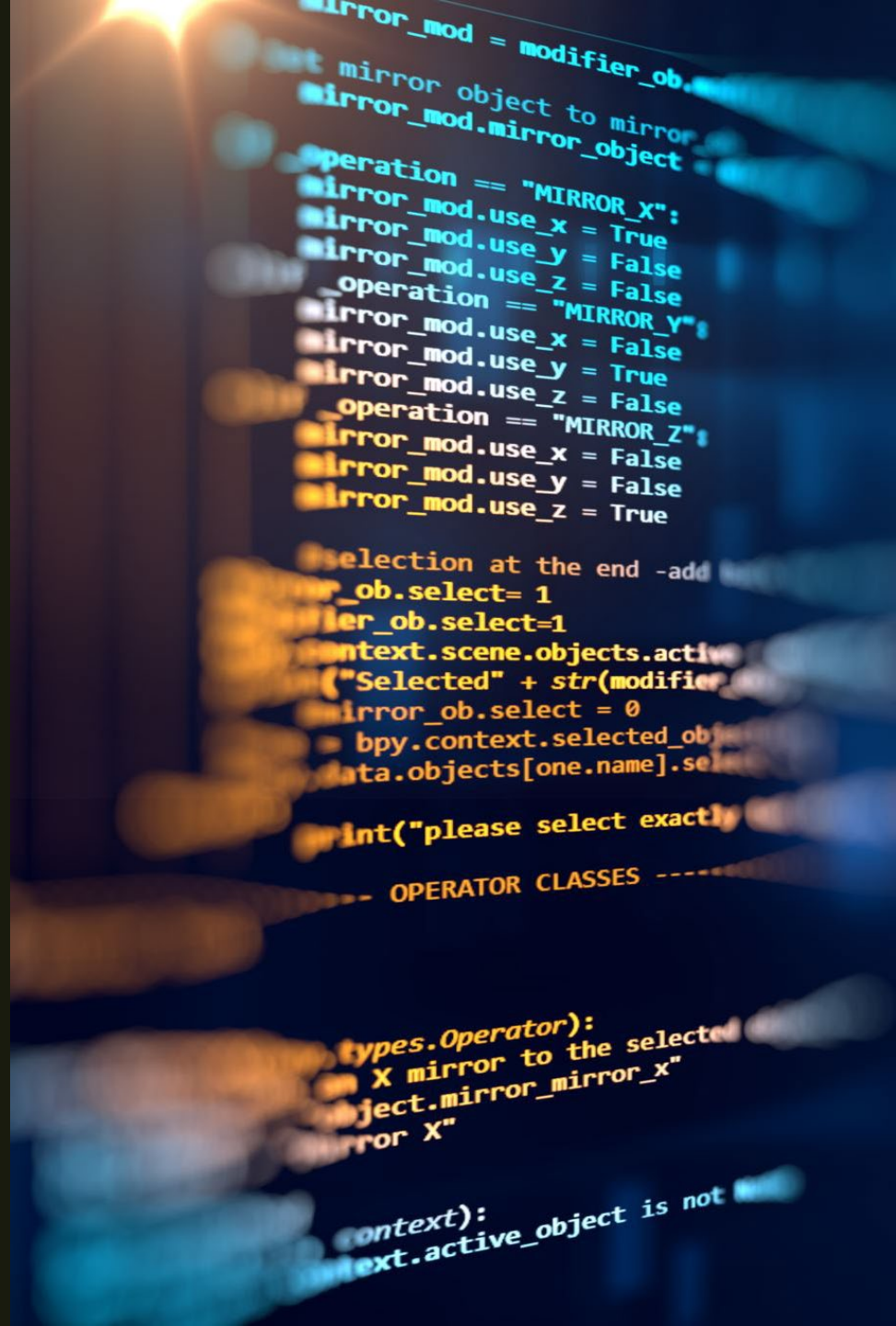
- **Rootkits:** provide a hacker with administrative access to a system.
- **Trojans:** give a hacker control over a system

## Buffer Overflows

- **Stack-based overflows:** overloading the region of memory used for storing temporary data
- **Heap-based overflows:** overflowing the region of memory used for dynamic memory allocation

## Keyloggers

- **Hardware keyloggers:** physical devices that are attached to a computer
- **Software keyloggers:** programs that run on a computer



# EFFECT OF SYSTEM HACKING

1. Ruin the victim's data by **deleting** the files.
2. **Steal** files and folders.
3. **Hijack** victim's **username** and **password.**
4. **Steal money** and **credit card details** while the victim is doing **e-marketing** or **online transaction.**
5. **Sell** victim's information to third parties who may use this information for illicit purposes.
6. Create **traffic to shut down** the victim's website.
7. Get access to the servers and **manipulate** the files, programs, etc.

# SYSTEM HACKING

## LINUX

- Linux is an Operating System (OS) assembled user the model of open-source software development and distribution and is based on Unix OS created by Linus Torvalds.
- Common hacking techniques on Linux:
  - Hack Linux using the SHADOW file.
  - Bypass the user password option in Linux.
  - Detects the bug on Linux distribution and tries to take advantage of it.

## WINDOWS

- Common hacking techniques on Windows:
  - Exploiting "zero-day" vulnerabilities
  - Bypass login by:
    - cracking the username and password,
    - installing backdoor through malware,
    - guess based on default (manufacture setting) settings,
    - etc.
  - Exploit the Common Weakness Exploitation (CWE) report

# SOFTWARE vs HARDWARE VULNERABILITIES

- Common Weakness Enumerations (CWE) list, included both categories of software and hardware vulnerabilities.
- Software exploitations of hardware vulnerabilities affect:
  - not only the computer systems, the cloud, but also the embedded computers within Internet-of-Things (IoT) devices.
- Example: Rowhammer
  - A design flaw in the internal memory (DRAM) chips of a device that creates the vulnerability that allow attacker control of a device.
  - CPU and DRAM manufacturers were eagerly looking for the definitive hardware solution to the Rowhammer problem.
  - Solution: They came up with Target Row Refresh (TRR).

# GAINING ACCESS

## 1. AUTHENTICATION

- The process or action of proving or showing something to be true, genuine, or valid
- Different type of authentication (MICROSOFT):
  - *Security Accounts Manager (SAM) Database:*
    - manage user accounts and passwords in hashed format (a one-way hash)
  - *NTLM Authentication:*
    - default authentication scheme that performs authentication using a challenge/response strategy. Consists of two protocols:
      - *NTLM authentication protocol and*
      - *LAN Manager (LM) authentication protocol.*
  - *Kerberos Authentication:*
    - network authentication protocol that provides strong authentication for client/server applications through secret-key cryptography.

# GAINING ACCESS

## 2. PASSWORD CRACKING

- Password cracking techniques are used to recover passwords from computer systems
- Attackers use password cracking techniques to gain unauthorized access to vulnerable systems
- Most of the password cracking techniques are successful because of weak or easily guessable passwords.

| | |
|---|---|
| Non-Electronic Attacks | Do not require any technical knowledge about hacking or system exploitation.<br>Example: Shoulder Surfing, Social Engineering, Dumpster Diving |
| Active Online Attacks | Performs password cracking by directly communicating with the victim's machine.<br>Example: Password Guessing, Keyloggers, Dictionary / Brute Force Attacks |
| Passive Online Attacks | Passively monitor or record the data passing over the communication channel, to and from the system.<br>Example: Wire Sniffing, Replay Attacks, Man in the Middle (MITM) Attacks |
| Offline Attacks | The attacker copies the target's password file and then tries to crack passwords on his own system at a different location.<br>Example: Rainbow Table Attack, Distributed Network Attack |

# PRIVILEGE ESCALATION

**Vertical** privilege escalation

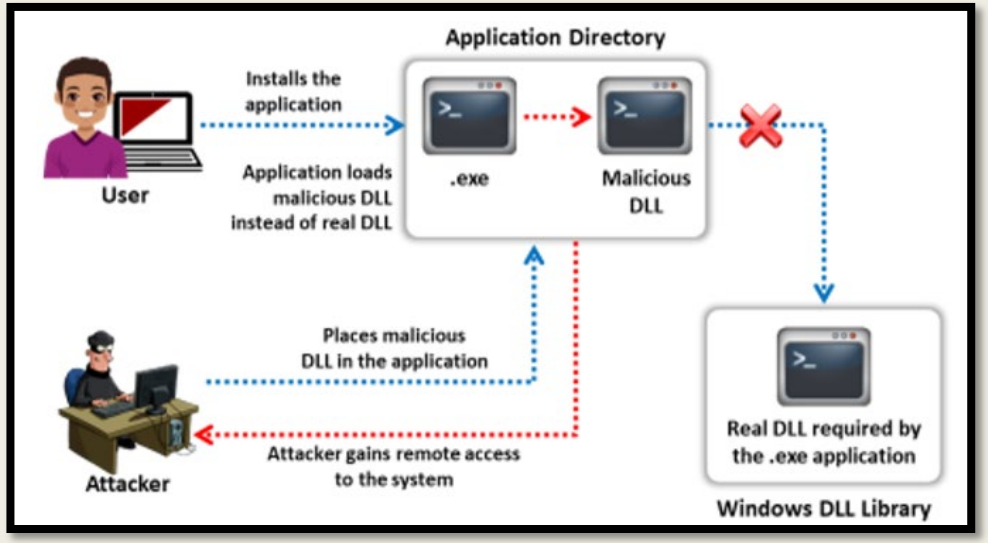
Starts with a **low-level account** and exploits a vulnerability to **gain a higher-level** account

**Horizontal** privilege escalation

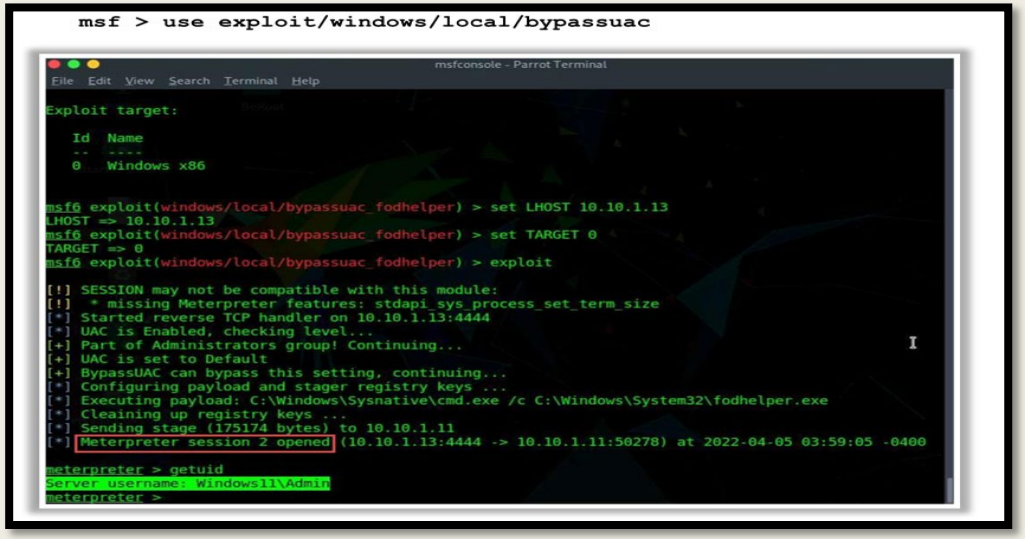
Uses the **existing account level** to **access resources** that should be **off-limits**

# PRIVILEGE ESCALATION: Example

- Using DLL Hijacking




- Bypassing User Account Control (UAC)




- Exploiting Vulnerabilities
  - Execute a command or binary on a target machine to **gain higher privileges** than those existing or to **bypass security mechanisms.**
  - Attackers search for an exploit based on the OS and software application on exploit sites such as Exploit Database(https://www.exploit-db.com) and VulDB (https://vuldb.com).

# DEFENDING: AGAINST PRIVILEGE ESCALATION

| | |
|---|---|
| Restrict | Restrict interactive logon privileges. |
| Run | Run users and applications with the lowest privileges. |
| Implement | Implement multi-factor authentication and authorization. |
| Use | Use an encryption technique to protect sensitive data. |
| Reduce | Reduce the amount of code that runs with a particular privilege. |
| Perform | Perform debugging using bounds checkers and stress tests. |
| Test | Thoroughly test the system for application coding errors and bugs. |
| Patch and update | Regularly patch and update the kernel. |

# MAINTAINING ACCESS

The malicious programs attackers execute on target systems can be:

| | |
|---|---|
| Backdoors | Gather information that leads to exploitation or loss of privacy or gain unauthorized access to system resources. |
| Crackers | Designed for cracking a code or passwords. |
| Keyloggers | Record each keystroke made on the computer keyboard. |
| Spyware | Capture screenshots and send them to a specified location defined by the hacker. |

# DEFENDING: AGAINST MAINTAINING ACCESS

| | |
|---|---|
| Change | Frequently change the password. |
| Give | Give access permissions based on user roles. |
| Perform | Perform system patch management periodically. |
| Deploy | Deploy a minimum privileges access model, which assists in restricting user access and domain admin account access. |
| Conduct | Conduct security awareness campaigns / training on phishing attacks, password creation policies, and other methods. |
| Adhere | Strictly adhere to password policies (in terms of password length, periodic updates, etc.) to enhance the security of individual account access. |

# CLEARING TRACKS

- Attackers may not wish to delete an entire log to cover their tracks, as doing so may require admin privileges.
- Delete only attack event logs.
- Manipulate the log files:
  - SECEVENT.EVT (security):
    - failed logins,
    - accessing files without privileges
  - SYSEVENT.EVT (system):
    - driver failure,
    - components or services not operating correctly
  - APPEVENT.EVT (applications):
    - application crashes / unhandled exceptions,
    - authentication or authorization failures,
    - validation errors, failed transactions,
    - suspicious or anomalous application activity

# CLEARING TRACKS

1. Disable Auditing
2. Covering Tracks on the Network / OS
3. Clearing Logs
4. Manipulating Logs
5. Deleting Files / Hiding Artifacts
6. Disabling Windows Functionality

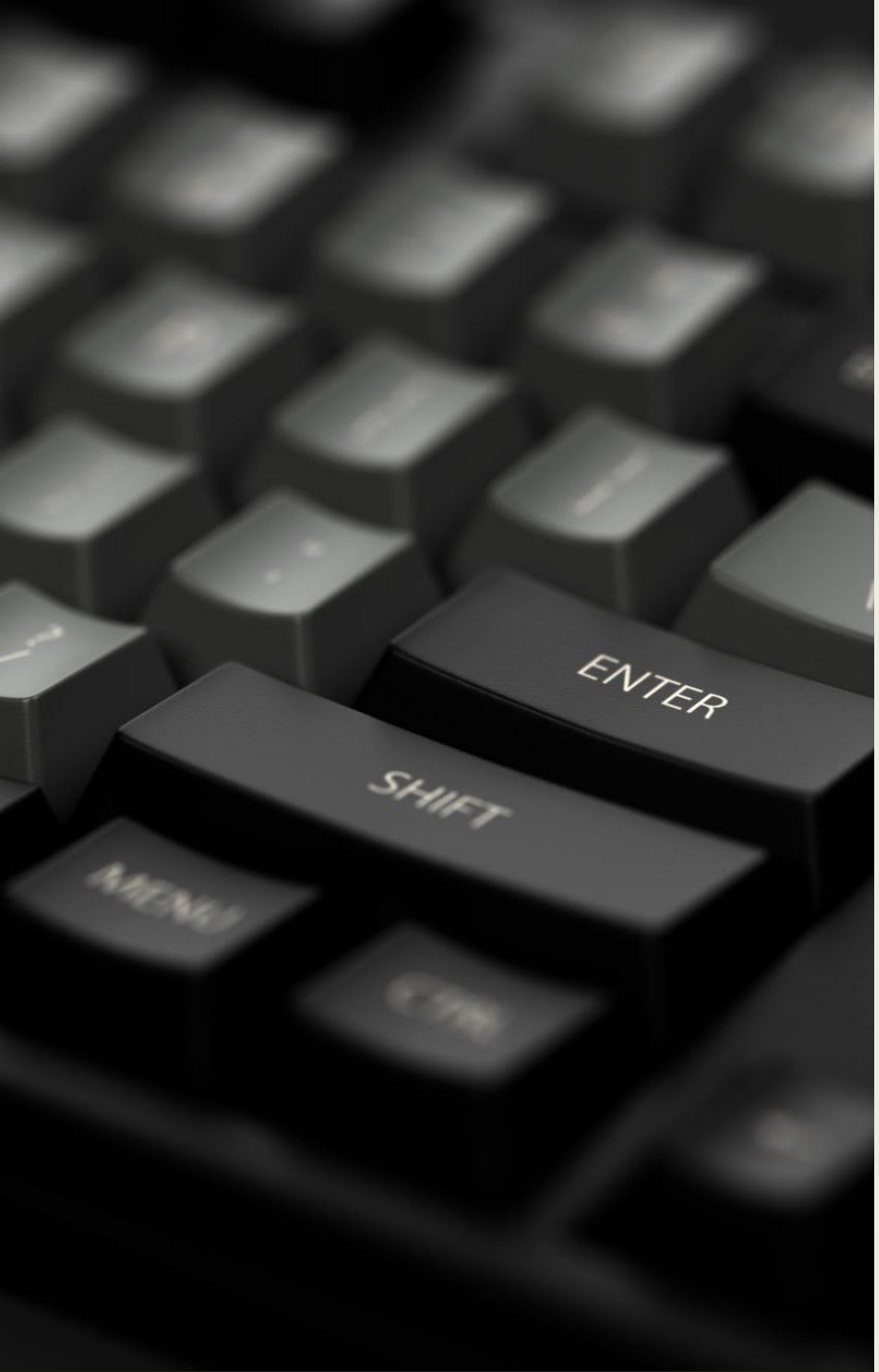
# CLEARING LOGS ONLINE

- Use private browsing
- Delete history in the address field
- Disable stored history
- Delete private data
- Clear cookies on exit
- Clear cache on exit
- Delete downloads
- Disable password manager
- Clear data in the password manager
- Delete saved sessions
- Delete user JavaScript
- Set up multiple users
- Remove Most Recently Used (MRU)
- Clear toolbar data from browsers
- Turn off AutoComplete

# DEFENDING: CLEARING TRACKS

- Activate the logging functionality on all critical systems.
- Conduct periodic audits on IT systems
- Configure the appropriate and minimal permissions necessary to read and write log files stored in critical systems.
- Regularly update and patch OSes, applications, and firmware.
- Close all unused open ports and services.
- Encrypt the log files
- Periodically back up the log files to unalterable media.
- Use restricted ACLs to secure the log files.

# Question
# &
# Answer




# ACTIVITY

1. Choose an application that you do not have an account
2. Create an account. Take note on the authentication method it has:
    1. *single or MFA,*
    2. *does it have password requirement*
3. Reset password:
    1. *how to reset password,*
    2. *does the new password have to based on the same requirement,*
    3. *does it have certain requirement like captcha*
4. Do fail login:
    1. *how many times is allowed,*
    2. *lockdown period, etc.*